SECURITY RESEARCH REPORT

מוצרים קיימים בשוק · המלצות OWASP LLM Top 10 · Anthropic · יחס ל-EHZ-SEC-AI

🗓️ אפריל 2026 🔬 מקורות: OWASP · docs.anthropic.com · מחקר שוק ✍️ הוכן ע"י EHZ-AI

10
סיכוני OWASP LLM

+7
מוצרי אבטחה בשוק

3
מנגנוני הגנה מובנים ב-CLAUDE

1
מוצר ייעודי לבדיקות HOOKS

0
מוצרים בדיוק כמו EHZ-SEC-AI

🎯 **מסקנה ראשית:** אין מוצר ייחודי בשוק שמנטר Claude Code דרך Hooks בזמן אמת עם Dashboard + Telegram + Hardening Levels. EHZ-SEC-AI ממלא פער אמיתי.

חלק א׳ — מה אומר ANTHROPIC עצמם על אבטחה

🏛️ עמדת Anthropic — עקרונות יסוד

Anthropic מפרסמים תיעוד מלא באתר code.claude.com/docs/en/security. הגישה שלהם: **Permission-based Architecture** — Claude Code מבצע קריאה בלבד כברירת מחדל. כל פעולה נוספת (כתיבה, פקודות) דורשת אישור מפורש.

🔒 הגנות מובנות

- ✅ Sandboxed Bash — בידוד filesystem+network
- ✅ Write restriction — רק בתיקיית הפרויקט
- ✅ Command blocklist — curl/wget חסומים כברירת מחדל
- ✅ Fail-closed — פקודה לא מוכרת → דורשת אישור

⚠️ מה Anthropic לא עושים

- ❌ אין Dashboard לניטור אירועים
- ❌ אין התראות Telegram/מייל על פעילות
- ❌ אין סריקת סיסמאות/secrets אוטומטית
- ❌ אין Hardening Levels מוגדרים
- ❌ אין Skill Scanner לפני התקנה
- ❌ אין Block Mode אוטומטי

✅ Isolated WebFetch context — מנגנון נגד Prompt Injection

✅ Command injection detection — פקודות חשודות → אישור ידני

📋 Best Practices לפי Anthropic

- 📌 בדוק כל פקודה לפני אישור
- 📌 אל תעביר תוכן לא מהימן ישירות ל-Claude
- 📌 השתמש ב-VM לסקריפטים מחיצוניים
- 📌 הפעל Hooks לניטור ובקרה
- 📌 אל תאפשר WebDAV ב-Windows (סיכון אבטחה)
- 📌 דווח על פעילות חשודה דרך /feedback

⚙️ Hooks — המנגנון הרשמי לאבטחה

Anthropic מספקים מנגנון Hooks ב-code.claude.com/docs/en/hooks — זהו **הבסיס הרשמי של EHZ-SEC-AI**. הם מספקים אפילו דוגמת קוד רשמית ב-GitHub.

סוג Hook	מתי רץ	יכולות	שימוש אבטחתי
PreToolUse	לפני ביצוע Tool	ALLOW DENY ASK DEFER	חסימת פקודות מסוכנות לפני ביצוע
PostToolUse	אחרי ביצוע Tool	לוגים, Feedback ל-Claude	ניטור, סריקת קבצים שנכתבו
PostToolUseFailure	כשTool נכשל	לוגים, התראות	זיהוי ניסיונות כושלים
HTTP Hook	כל אירוע	שליחה ל-endpoint חיצוני	← **זה בדיוק EHZ-SEC-AI!**

קוד רשמי מ-HTTP Hook — Anthropic לשרת חיצוני (בדיוק הארכיטקטורה של EHZ-SEC-AI):

```
// Hook — settings.json עם HTTP endpoint
{
  "hooks": {
    "PreToolUse": [{
      "matcher": "Bash",
      "hooks": [{
        "type": "http",
        "url": "http://localhost:3010/hooks/pre-tool-use",  ← EHZ Collector
        "timeout": 30,
        "headers": { "Authorization": "Bearer $CCSM_TOKEN" }
      }]
    }]
  }
}
```

🐙 **Reference Implementation רשמי:** Anthropic פרסמו Hook — bash_command_validator_example.py שחוסם grep ו-find ומאלץ שימוש ב-ripgrep. מדגים בדיוק את Pattern שבו EHZ-SEC-AI משתמש.

📊 OpenTelemetry — ניטור רשמי ל-Enterprise

Anthropic מספקים תמיכה מלאה ב-OpenTelemetry דרך `CLAUDE_CODE_ENABLE_TELEMETRY=1`. מתאים לארגונים עם Prometheus / Grafana / Splunk / Datadog.

`claude_code.session.count`
מספר Sessions שנפתחו

`claude_code.token.usage`
שימוש ב-Tokens (input/output/cache)

`claude_code.cost.usage`
עלות ב-USD לכל session

`claude_code.lines_of_code.count`
שורות קוד שנוספו/הוסרו

`claude_code.tool_result`
אירוע לכל tool שהושלם (success/fail + duration)

`claude_code.tool_decision`
כל החלטת accept/reject של tool

`OTEL_LOG_TOOL_DETAILS=1`
הפעלה: פרמטרים מלאים של כל tool (פקודות Bash, נתיבי קבצים)

`OTEL_LOG_USER_PROMPTS=1`
תיעוד תוכן הפרומפטים (כבוי כברירת מחדל)

⚠️ **הבדל מ-EHZ-SEC-AI:** OpenTelemetry = מוכוון ROI ועלויות, לא אבטחה. אין זיהוי אנומליות, אין Hardening Levels, אין Secrets Scanner. EHZ-SEC-AI משלים את הפער הזה.

חלק ב׳ — OWASP TOP 10 סיכוני LLM (2024)

OWASP פרסמו רשימת 10 הסיכונים הקריטיים ליישומי LLM. לכל סיכון — כיצד EHZ-SEC-AI מטפל בו.

`LLM01`
Prompt Injection
תוקף מחדיר הוראות זדוניות דרך קלט לגרום לLLM לבצע פעולות לא מורשות.

🛡 EHZ-SEC-AI: זיהוי context חשוד ב-PreToolUse Hook

`LLM02`
Insecure Output Handling
אי-ולידציה של פלט LLM מאפשרת RCE, XSS, SQL Injection במערכות downstream.

🛡 EHZ-SEC-AI: PostToolUse סריקת קוד שנכתב

`LLM03`
Training Data Poisoning
זיהום נתוני אימון גורם לתגובות שפוגעות באבטחה, דיוק, התנהגות אתית.

🔵 מחוץ לסקופ — בצד Anthropic

`LLM04`
Model Denial of Service
הצפת המערכת בפעולות עתירות משאבים גורמת לשיבוש ועלויות.

🛡 EHZ-SEC-AI: Behavioral Rules — >20 WebFetch/min → ALERT

`LLM05`
Supply Chain Vulnerabilities

`LLM06`
Sensitive Information Disclosure

תלות ברכיבים/שירותים/datasets פגומים פוגעת בשלמות המערכת.

🛡 EHZ-SEC-AI: Skill Scanner — Hash + YARA לפני כל התקנה

חשיפת מידע סודי בפלטים יוצרת סיכונים משפטיים ותחרותיים.

🛡 EHZ-SEC-AI: Secrets Scanner — סיסמאות, API keys, כרטיסי אשראי, ת"ז

LLM07

Insecure Plugin Design

Plugins שמטפלים בקלט לא מהימן ללא הגבלות גישה מאפשרים RCE.

🛡 EHZ-SEC-AI: MCP Hook monitoring + Skill pre-install scan

LLM08

Excessive Agency

אוטונומיה בלתי מוגבלת מובילה לתוצאות לא מכוונות שפוגעות בפרטיות ואמינות.

🛡 EHZ-SEC-AI: Hardening Levels 0-3 + Block Mode (Milestone 10)

LLM09

Overreliance

אמון עיוור בפלטי LLM יכול להוביל לפגיעויות אבטחה והחלטות שגויות.

🔵 אחריות משתמש + Session Recording (Milestone 7)

LLM10

Model Theft

גישה לא מורשית למודלים קנייניים מסכנת יתרון תחרותי ומדליפה מידע.

🔵 מחוץ לסקופ — בצד Anthropic/API

סיכום EHZ-SEC-AI **OWASP:** מטפל ב-7 מתוך 10 סיכוני OWASP LLM. 3 הנותרים (LLM03, LLM09 חלקי, LLM10) הם ברמת Anthropic/API ומחוץ לשליטת הלקוח.

חלק ג' — מוצרים קיימים בשוק

Lasso Security

Enterprise / Paid

פלטפורמת אבטחת AI לארגונים. מגלה Shadow AI, מנטרת agents, ומגנה בזמן אמת. לקוחות: DHS ו-Fortune 500.

- ✓ Discover — מזהה כל מודל AI ואפליקציה בארגון
- ✓ Assess — הערכת סיכונים ופגיעויות
- ✓ Red Teaming — Test אוטומטי
- ✓ Guardrails — Enforce התנהגותיים
- ✓ Protect — זיהוי כוונה זדונית בזמן אמת (<50ms)
- ✓ DLP — מניעת דליפת מידע

lasso.security

Enterprise pricing

Spectral (Check Point)

Paid — חלק מ-CloudGuard

כלי סריקת secrets וסיסמאות בקוד. Developer-first. מזהה credentials, API keys, misconfigurations לפני שמגיעים ל-repo.

- ✓ Secrets sprawl prevention — מניעת פיזור סיסמאות

- ✓ API security monitoring
- ✓ Software Composition Analysis (SCA)
- ✓ Code vulnerability detection
- ✓ Real-time scanning בזמן coding

spectralops.io

Paid — CloudGuard suite

YARA

Open Source / חינמי

כלי זיהוי malware מבוסס חוקים. משמש ב-SOC, AV חברות, ומחקר אבטחה. מאפשר כתיבת חוקים מותאמים לזיהוי קוד/קבצים חשודים.

- ✓ Pattern matching מדויק על קבצים
- ✓ חוקים קהילתיים לאלפי סוגי malware
- ✓ ניתן להפעיל מ-CLI / Python / Node.js
- ✓ מהירות גבוהה — סריקת Skills לפני התקנה
- ✓ LoL (Living off the Land) rules

virustotal.github.io/yara

✓ חינמי

Semgrep

Community Free / Paid Pro

Static Analysis לקוד. מוצא bugs, vulnerabilities, ו-security patterns בקוד שנכתב. תומך ב-30+ שפות. משמש גם לסריקת קוד AI-generated.

- ✓ סריקת קוד שנכתב על ידי Claude
- ✓ חוקי OWASP Top 10 מובנים
- ✓ זיהוי hardcoded secrets
- ✓ תמיכה ב-JavaScript, Python, TypeScript, Go ועוד
- ✓ CI/CD integration

semgrep.dev

✓ COMMUNITY FREE

VirusTotal API

Free 500/day · API

שירות של Google לסריקת קבצים ו-URLs מול 70+ מנועי AV. API חינמי עד 500 בקשות/יום. ניתן לשלב בסריקת Skills לפני התקנה.

- ✓ 70+ מנועי AV במקביל

- ✓ סריקת קבצים, URLs, domains
- ✓ API חינמי — 500 req/day
- ✓ Hash lookup — אם כבר נסרק, תוצאה מיידית
- ✓ ממצאים של קהילת חוקרי אבטחה

virustotal.com/api

✓ FREE TIER

ClamAV

חינמי / Open Source

מנוע open source AV של Cisco. מקומי לחלוטין, ללא גבולות. מסד נתונים מתעדכן אוטומטית. עובד על Windows/Linux.

- ✓ מקומי — לא שולח קבצים לענן
- ✓ עדכוני מסד נתונים אוטומטיים
- ✓ ללא הגבלת סריקות
- ✓ Node.js binding זמין
- ✓ ניתן לשלב בסריקת Skills

clamav.net

✓ חינמי

Google Safe Browsing

Free 10K/day

API של Google לבדיקת URLs מסוכנים — phishing, malware, unwanted software. בשימוש Chrome, Firefox, Safari. 10,000 בקשות/יום חינמי.

- ✓ בדיקת כל URL שClaude מנסה לגשת אליו
- ✓ Phishing detection בזמן אמת
- ✓ Malware hosting detection
- ✓ 10,000 req/day — מספיק לכל שימוש
- ✓ Lookup API — batch בקשות

safebrowsing.google.com

✓ FREE TIER

Claude Code ROI Guide

רשמי מ-Anthropic

מדריך רשמי מ-Anthropic לניטור OpenTelemetry + Prometheus + Docker Compose. מוכוון ROI ועלויות — Claude Code. לא אבטחה.

- ✓ מוכן Prometheus + Docker Compose
- ✓ Cost tracking per session/user

✓ Token usage analytics

✓ PR/Commit productivity metrics

✓ Linear עם Integration

🌐 github.com/anthropics/claude-code-monitoring-guide

✓ חינמי

חלק ד' — טבלת השוואה — EHZ-SEC-AI מול השוק

פיצ'ר	LASSO	SPECTRAL	SEMGREP	OTEL GUIDE	EHZ-SEC-AI
ניטור Claude Code Hooks	❌	❌	❌	⚠️ חלקי	✅
Dashboard ניהול בזמן אמת	✅	⚠️	❌	⚠️ Grafana	✅
התראות Telegram	❌	❌	❌	❌	✅
Secrets / DLP Scanner	✅	✅	✅	❌	✅
Hardening Levels 0-3	⚠️	❌	❌	❌	✅
Skill Scanner (לפני התקנה)	❌	❌	❌	❌	✅
Anomaly Detection Rules	✅	⚠️	❌	❌	✅
Block Mode (עצירת Claude)	✅	❌	❌	❌	✅ Milestone 10
System Tray	❌	❌	❌	❌	✅
Domain / Active Directory	✅	✅	⚠️	✅	✅ Milestone 9
SIEM Integration	✅	✅	⚠️	⚠️	✅ Milestone 11
מחיר	💰 Enterprise	Paid 💰	💰 / 🆓	חינמי 🆓	חינמי + שלנו 🆓

חלק ה' — תובנות ומסקנות

🎯 **EHZ-SEC-AI** ממלא פער אמיתי

✅ **Anthropic** מאשרים את הגישה שלנו

אין מוצר בשוק שמנטר Claude Code ספציפית דרך Anthropic Hooks. מספקים את ה-*מנגנון* (Hooks API) אבל לא *מוצר* מלא. EHZ-SEC-AI הוא השכבה שחסרה.

הארכיטקטורה של EHZ-SEC-AI — HTTP Hook ל-Collector מקומי — היא בדיוק מה שAnthropic מדגימים בתיעוד הרשמי שלהם. אנחנו בכיוון הנכון.

⚡

OpenTelemetry כאלטרנטיבה משלימה

OTel של Anthropic מצוין לניטור ארגוני (עלויות, tokens, ROI) אבל לא לאבטחה. שווה לשקול לשלב OTel + EHZ-SEC-AI — כל אחד עושה משהו אחר.

🔒

7/10 סיכוני OWASP מכוסים

EHZ-SEC-AI מטפל ב-70% מסיכוני OWASP LLM Top 10. הנותרים (Data Poisoning, Model Theft) הם ברמת Anthropic ומחוץ לשליטת המשתמש.

VS

יתרון על פני Lasso ו-Spectral

המוצרים הפעידים (Lasso, Spectral) הם Enterprise בתשלום. EHZ-SEC-AI חינמי, מותאם אישית ל-Claude Code, ועם System Tray + Telegram שאין במוצרים אחרים.

⚠️

סיכון WebDAV ב-Windows

Anthropic מזהירים במפורש: אל תאפשר WebDAV ב-Claude — Windows יכול לבצע network requests לhosts חיצוניים ולעקוף את EHZ-SEC-AI. Permission System. צריך לכסות את הסיכון הזה.

המלצות — כיצד לשפר EHZ-SEC-AI בהתבסס על המחקר

📋 **5 שיפורים מיידיים שהמחקר חשף**

🔴 **חשוב — הוסף לRules**

חסימת WebDAV paths ב-.(prefix `\\*`) Windows Anthropic מזהירים במפורש מסיכון זה.

🟠 **שקול שילוב OTel**

הוסף תמיכה ב-OpenTelemetry output — כך EHZ-SEC-AI יכול להזין נתונים גם ל-Grafana/Prometheus ארגוניים.

🟡 **Prompt Injection Detector**

OWASP LLM01. הוסף זיהוי patterns של Prompt Injection בתוכן שClaude מקבל (WebFetch results, file reads).

🔵 **MCP Hook Monitoring**

Anthropic מציינים MCP כסיכון אבטחה. הוסף matcher ל- `mcp__*__write*` לניטור כל כתיבה דרך MCP servers.

🟢 **ConfigChange Hook**

Anthropic מספקים hook `ConfigChange` — התראה כשמישהו משנה את settings.json. חשוב לאבטחה ב-Domain.

EHZ-AI | Claude Code Security Monitor — Security Research Report
מקורות: Spectral · Lasso Security · OWASP LLM Top 10 · code.claude.com/docs/en/hooks · code.claude.com/docs/en/security
VirusTotal · Semgrep · YARA
נוצר: אפריל 2026 | הדף נבנה ע"י **EHZ-AI | 054-4825276**